

fighting spam

Lo spam o il phishing sono tecniche di invio massiccio di email da parte di zombie-computers che si collegano allo stesso SMTP e mandano email in massa.

Se lo spammer è un MUA è facile da identificare dal suo stesso MSA, in uqnado pria di mandare le amil dovrà autenticarsi presso esso, se invece è MTA, l'MTA ricevente non riesce a distinguere gli invii safe da quelli no.

ip based anti spam techniques

FQDN check

Il comando Helo deve contenere un damain name, in modo tale che il server possa fare una query al DNS trovando il suo IP. Farà inoltre una una Reverse DNS query per controllare che l'IP fornito corrisponda al domain fornito; infine controlla se l'IP fornito è quello che ha inizializzato la connessione.

IP blacklisting

molte organizzazioni tengono una list aaggiornata con gli indirizzi IP sia statici che dinamici che sono stati scoperti generare messaggi spam. Poichè sono segnati anche quelli dinamici che spaziano molto probabilmente anche l'IP della tua rete locale sarà all'interno di una blacklist

graylisting

quando un MTA riceve un errore, dovrebbe riprovare l'invio dopo poco tempo, gli spammers non lo faranno piuttosto passeranno al prossimo SMTP target senza perdere tempo.

- quando un MTA si connette al server egli manda un errore e segna l'IP su una whitelist
- se il client è legittimo farà un altro tentativo di invio, e il server permetterà la connessione in quanto l'IP del MTA è nella whitelist
- non è dispendioso ma crea delay al primo invio di una mail da parte di un MTA legit e uno spammer può essere paziente e riprovare .

HELO/EHLO: nome del dominio del MTA, server che agisce come client

MAIL FROM: indica dove inviare gli errori, che può essere un indirizzo email diverso dal mittente

from: nome del mittente inserito nella mail del ricevente e l'indirizzo usato per rispondere.

sender spoofing

un singolo SMTP client può usare in maniera legittima from: con tanti domains diversi.

UN MTA non può dropare una mail in arrivo perchè ci sono discrepanze tra From: , MAIL FROM e HELO.

questo è usato per scammare perchè è molto più credibile una mail che proviene da un domain noto.

consideriamo un sottodominio di unive.it che viene attaccato e l'hacker ne ottiene pieno possesso. Potrà scaricarci un MTA fraudolento e usare l'IP pulito di unive.it che non compare in nessuna blacklist, e passare il FQDN in quanto ha un IP pubblico.

SPF



si assume che l'attaccante che prende possesso di un'infrastruttura di un'organizzazione non possa modificarne il DNS.

SPF è un protocollo per proteggersi da spammers che usano HELO o MAIL FROM che non gli appartengono. All'interno del DNS infatti è presente una SPF entry che contiene una lista di IP che possono inviare mail da quel domain.

quando viene eseguita una controllo a DSN l'IP ottenuto va controllato anche sulla entry SPF se quel DSN n è munita.

DKIM: email fields Authentication

I campi all'interno dell'header della mail sono impostabili solamente dal MUA. Quindi l'MSA autentica lo user e controlla che il campo from: usato dal MUA sia autorizzato per quel MSA, funziona similmente a SPF ma con un aggiunta di crittografia; l'MSA possiede un paio di chiavi pubblica/privata. l'MSA firma il messaggio con la sua chiave privata, quindi il prossimo MTA che rieve l'email potrà verificarne legittimità, assumendo conosca la chiave pubblicac dell'MSA.

La chiave pubblica è messa all'interno delle informazioni del DNS, deve essere pubblicato sotto al dominio selector._domainkey.domain.

DMARC alignment

controllo dell'header affinche corrisponda almeno uno dei seguenti campi: d= nella firma DKIM o domain verificato dall'SPF. Una volta controllati tutti i parametri (HELO, MAIL FROM e From) l'MTA deve decidere a seconda dei risultato se scartare o no la mail. Per uniformare una policy valida per tutto il domain è inserito all'interno del DNS

